

Fix: Privilege Escalation in MLflow when using spark_udf #10874

New issue

Merged

WeichenXu123 merged 3 commits into `mlflow:master` from `WeichenXu123:fix-spark_udf-privilege-escalation` on Jul 24, 2024

Conversation 7

Commits 3

Checks 0

Files changed 1

+2 -2



WeichenXu123 commented on Jan 23, 2024

Collaborator

• edited

▸ DevTools ▮

Related Issues/PRs

#xxx
[#10869](#)

What changes are proposed in this pull request?

Fix Privilege Escalation in MLflow when using spark_udf

How is this PR tested?

- ☒ Existing unit/integration tests
- ☐ New unit/integration tests
- ☐ Manual tests

Does this PR require documentation update?

- ☒ No. You can skip the rest of this section.
- ☐ Yes. I've updated:

☐ Examples

☐ API references

☐ Instructions

Release Notes

Is this a user-facing change?

Reviewers

serena-ruan

✓

Assignees

No one assigned

Labels

area/scoring

rn/none

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

4 participants



- ☒ No. You can skip the rest of this section.
- ☐ Yes. Give a description of this change to be included in the release notes for MLflow users.

What component(s), interfaces, languages, and integrations does this PR affect?

Components

- ☐ `area/artifacts` : Artifact stores and artifact logging
- ☐ `area/build` : Build and test infrastructure for MLflow
- ☐ `area/deployments` : MLflow Deployments client APIs, server, and third-party Deployments integrations
- ☐ `area/docs` : MLflow documentation pages
- ☐ `area/examples` : Example code
- ☐ `area/model-registry` : Model Registry service, APIs, and the fluent client calls for Model Registry
- ☐ `area/models` : MLmodel format, model serialization/deserialization, flavors
- ☐ `area/recipes` : Recipes, Recipe APIs, Recipe configs, Recipe Templates
- ☐ `area/projects` : MLproject format, project running backends
- ☒ `area/scoring` : MLflow Model server, model deployment tools, Spark UDFs
- ☐ `area/server-infra` : MLflow Tracking server backend
- ☐ `area/tracking` : Tracking Service, tracking client APIs, autologging

Interface

- ☐ `area/uiux` : Front-end, user experience, plotting, JavaScript, JavaScript dev server
- ☐ `area/docker` : Docker use across MLflow's components, such as MLflow Projects and MLflow Models
- ☐ `area/sqlalchemy` : Use of SQLAlchemy in the Tracking Service or Model Registry
- ☐ `area/windows` : Windows support

Language

- ☐ `language/r` : R APIs and clients
- ☐ `language/java` : Java APIs and clients
- ☐ `language/new` : Proposals for new client languages

Integrations

- ☐ `integrations/azure` : Azure and Azure ML integrations
- ☐ `integrations/sagemaker` : SageMaker integrations
- ☐ `integrations/databricks` : Databricks integrations

How should the PR be classified in the release notes?
Choose one:

- ☒ `rn/none` - No description will be included. The PR will be mentioned only by the PR number in the "Small Bugfixes and Documentation Updates" section
- ☐ `rn/breaking-change` - The PR will be mentioned in the "Breaking Changes" section
- ☐ `rn/feature` - A new user-facing feature worth mentioning in the release notes
- ☐ `rn/bug-fix` - A user-facing bug fix worth mentioning in the release notes
- ☐ `rn/documentation` - A user-facing documentation change worth mentioning in the release notes

  `init` ...

4e54bb9



github-actions bot commented

Contributor

on Jan 23, 2024 • edited ▾

Documentation preview for [001cc17](#) will be available when [this CircleCI job](#) completes successfully.

- [Top page](#)
- [Changed pages](#)

► More info

  **github-actions** bot added `rn/none` `area/scoring` and removed `rn/none` labels on Jan 23, 2024

  **WeichenXu123** requested a review from **serena-ruan** 2 years ago



 **serena-ruan** reviewed View reviewed changes
on Jan 24, 2024

mlflow/pyfunc/__init__.py Outdated

...	...	@@ -917,7 +917,7 @@ def _create_model_dir
917	917	tmp_model_dir = tempfile.mkdtemp
918	918	# mkdtemp creates a directory w
919	919	# change it to be 0o777 to ensu

 **serena-ruan** on Jan 24, 2024

Collaborator

Update comment?



serena-ruan approved these changes [on Jan 24, 2024](#)

[View reviewed changes](#)

serena-ruan left a comment

Collaborator

LGTM!



[update](#)



[63bef57](#)



WeichenXu123 commented

Collaborator

Author

[on Jan 25, 2024](#)

I remember previously we have permission issue on databricks NFS which also relates to this directory permission setting, Let me test this on databricks NFS too.



efabgp commented [on May 29, 2024](#)

Hey there! Is there a reason that this is not merged yet? We would appreciate this issue being fixed since it is listed as a critical vulnerability.



WilliamRoyNelson commented [on Jul 20, 2024](#)

[@serena-ruan](#)

Are there additional steps that need to be done in order for this to be merged? It's been half a year.



WeichenXu123 commented

Collaborator

Author

[on Jul 22, 2024](#)

[@serena-ruan](#) Are there additional steps that need to be done in order for this to be merged? It's been half a year.

Oh sorry for the delay, I am searching the old cases and verify them. Will complete it next few days.



1



Merge branch 'mlflow:master'
into fix-spark_udf-privilege-
escalation

Verified

001cc17



WeichenXu123 merged commit **0b1d995** into
mlflow:master on Jul 24, 2024